FACULDADE DE TECNOLOGIA PADRE DANILO JOSÉ DE OLIVEIRA OHL

DANILO DE CASTRO GOMES
GABRIEL TAVARES BENTO
GUILHERME RODRIGUES DE LIMA
ROGER FERREIRA CARDOSO

PROJETO ACTIVE DIRECTORY:
DIRETRIZES DE GOVERNANÇA, ESTRUTURAÇÃO E PADRONIZAÇÃO

BARUERI
2026

DANILO DE CASTRO GOMES
GABRIEL TAVARES BENTO
GUILHERME RODRIGUES DE LIMA
ROGER FERREIRA CARDOSO

PROJETO ACTIVE DIRECTORY:
DIRETRIZES DE GOVERNANÇA, ESTRUTURAÇÃO E PADRONIZAÇÃO

Monografia apresentada à Faculdade de Tecnologia de Barueri como requisito final para obtenção do título de tecnólogo. Orientador(a): Prof(a). VANDER RIBEIRO ELME

BARUERI
2026

RESUMO

O presente trabalho descreve o projeto de implementação, estruturação e estabelecimento de diretrizes de governança para o Active Directory (AD) no domínio adm.fatecbarueri.local da Faculdade de Tecnologia de Barueri (Fatec Barueri). O objetivo central é estabelecer normas rigorosas de segurança, padronização de nomenclatura, controle de privilégios e estruturação lógica em Unidades Organizacionais (OUs), segregando os ambientes acadêmico e administrativo. A metodologia abrange a definição de regras de segregação de funções (SoD), o princípio do menor privilégio, e a automação do ciclo de vida de identidades, assegurando a conformidade com frameworks de governança como ITIL, COBIT e ISO 27001. O estudo consolida os critérios técnicos exigidos pelo Centro Paula Souza (CPS) e fornece uma arquitetura escalável, segura e altamente disponível para a infraestrutura tecnológica da instituição.

Palavras-chave: Active Directory. Governança de TI. Segurança da Informação. Fatec Barueri. Administração de Redes.

ABSTRACT

This work describes the implementation project, structuring, and establishment of governance guidelines for the Active Directory (AD) in the adm.fatecbarueri.local domain at the Faculdade de Tecnologia de Barueri (Fatec Barueri). The main objective is to establish strict security standards, naming conventions, privilege control, and logical structuring into Organizational Units (OUs), segregating academic and administrative environments. The methodology covers the definition of segregation of duties (SoD) rules, the principle of least privilege, and the automation of the identity lifecycle, ensuring compliance with governance frameworks such as ITIL, COBIT, and ISO 27001. The study consolidates the technical criteria required by the Centro Paula Souza (CPS) and provides a scalable, secure, and highly available architecture for the institution's technological infrastructure.

Keywords: Active Directory. IT Governance. Information Security. Fatec Barueri. Network Administration.

SUMÁRIO

1. INTRODUÇÃO **6**
2. CONTROLE DE CONTAS PRIVILEGIADAS E SEGREGAÇÃO DE FUNÇÕES **6**
2.1. DIRETRIZES DE SEGREGAÇÃO E TIPOS DE CONTAS 6
3. CONVENÇÃO DE NOMENCLATURA E PADRONIZAÇÃO **7**
3.1. CONVENÇÃO DE NOMENCLATURA DE COMPUTADORES 7
3.2. CONVENÇÃO DE NOMENCLATURA DE UTILIZADORES 7
4. CRITÉRIOS DE ELEGIBILIDADE E CICLO DE VIDA DE GRUPOS **7**
5. ESTRUTURA LÓGICA E HIERÁRQUICA DE UNIDADES ORGANIZACIONAIS (OUs) **8**
5.1. RAMO ACADÊMICO (AD-ACAD) 8
5.2. RAMO ADMINISTRATIVO (AD-ADM) 8
5.3. REPRESENTAÇÃO DA ÁRVORE DE DIRETÓRIOS 8
6. FLUXOS DE PROVISIONAMENTO E CICLO DE VIDA DE IDENTIDADES **9**
6.1. PROVISIONAMENTO DE CONTAS 9
6.2. MANUTENÇÃO E ALTERAÇÕES CADASTRAIS 11
6.3. GESTÃO E RECUPERAÇÃO DE CREDENCIAIS 12
6.4. DESLIGAMENTO, RETENÇÃO E EXPURGO 12
7. POLÍTICAS DE SEGURANÇA E GOVERNANÇA **13**
7.1. POLÍTICA DE CREDENCIAIS 13
7.2. REGRAS DE BLOQUEIO DE CONTAS 14
8. CONCLUSÃO **14**

1. INTRODUÇÃO

A infraestrutura de serviços de diretório da Fatec Barueri está estruturada sob o domínio raiz adm.fatecbarueri.local. Este identificador centraliza a autenticação, a autorização e a gestão de políticas de grupo (GPOs) de todo o ecossistema tecnológico da instituição, servindo de base para a segmentação lógica entre os ambientes acadêmico (AD-ACAD) e administrativo (AD-ADM).

No cenário atual de tecnologia da informação, a gestão centralizada de identidades e acessos é um pilar fundamental para a segurança cibernética e a governança corporativa. Diante das complexidades operacionais de uma instituição de ensino superior, que engloba um vasto número de discentes, docentes e colaboradores administrativos, a adoção e a configuração adequada do Active Directory (AD) tornam-se imperativas.

Neste contexto, o presente projeto de monografia visa documentar e normatizar todas as diretrizes institucionais para a criação, uso, monitoramento e revisão de contas, grupos e unidades organizacionais, garantindo o alinhamento com as normas do Centro Paula Souza (CPS) e melhores práticas globais de segurança.

2. CONTROLE DE CONTAS PRIVILEGIADAS E SEGREGAÇÃO DE FUNÇÕES

A governança no domínio adm.fatecbarueri.local baseia-se no princípio do menor privilégio (Principle of Least Privilege – PoLP), rastreabilidade e administração centralizada pela equipe de TI. A gestão de acessos rege-se pelas políticas de Segregação de Funções (Segregation of Duties – SoD), visando impedir que uma única credencial concentre o controle absoluto sobre a rede.

2.1. DIRETRIZES DE SEGREGAÇÃO E TIPOS DE CONTAS

Para assegurar a governança técnica e a proteção do diretório, é obrigatória a separação entre a conta comum (utilizada para o dia a dia, como e-mails e sistemas) e a conta administrativa (utilizada exclusivamente para gerenciar o Active Directory, servidores e GPOs). O ambiente possui os seguintes tipos de contas:

• Administrativas Individuais: Exclusivas e não compartilhadas para membros da TI.

• De Serviço: Restritas a aplicações e serviços específicos, sem login interativo.

• De Emergência: Uso restrito a falhas críticas, com registro e auditoria obrigatórios pós-utilização.

3. CONVENÇÃO DE NOMENCLATURA E PADRONIZAÇÃO

3.1. CONVENÇÃO DE NOMENCLATURA DE COMPUTADORES

A padronização da nomenclatura de computadores constitui um requisito essencial para a administração centralizada do Active Directory, garantindo consistência operacional e alinhamento com as normas institucionais do CPS. Os nomes dos computadores são compostos por quatro elementos sequenciais, estritamente sem a utilização de hífens ou caracteres especiais:

• Unidade: Código numérico atribuído pela CPS que identifica a Fatec responsável.

• Local: Código alfanumérico que representa o laboratório, sala ou setor.

• Número do Local: Dígito que detalha o espaço físico específico.

• Número da Máquina: Identificador unívoco do equipamento, registrado de forma contínua e sem separadores.

3.2. CONVENÇÃO DE NOMENCLATURA DE UTILIZADORES

Da mesma forma, a padronização para utilizadores é um requisito fundamental. Para garantir a consistência e evitar ambiguidades no diretório, o logon principal não utiliza domínios institucionais completos, retendo apenas a base nominal do utilizador, conforme estipulado pelas normas da instituição.

4. CRITÉRIOS DE ELEGIBILIDADE E CICLO DE VIDA DE GRUPOS

Para mitigar o crescimento desordenado do diretório (group bloat) e assegurar o alinhamento com os frameworks de governança, a criação de novos grupos exige

justificativa técnica formal via sistema de chamados (ITSM) e validação rigorosa da equipe de infraestrutura.

• Prevenção de Redundância: Validação obrigatória para impedir a criação de grupos com propósitos idênticos.
• Propriedade (Owner): Exigência de um gestor formalmente documentado responsável por grupos críticos.
• Grupos Temporários: Registro da data de expiração no campo Notes e exclusão programada para reduzir o token Kerberos.
• Auditoria e Revisão: Execução de revisões semestrais de acessos mediante exportação de filiações.

5. ESTRUTURA LÓGICA E HIERÁRQUICA DE UNIDADES ORGANIZACIONAIS (OUs)

A organização lógica do diretório no domínio adm.fatecbarueri.local encontra-se estruturada em dois grandes ramos operacionais, permitindo a segregação estrita entre os recursos acadêmicos e corporativos. A arquitetura viabiliza a aplicação centralizada de políticas de grupo (GPOs) e a delegação granular de privilégios.

5.1. RAMO ACADÊMICO (AD-ACAD)

Concentra a estrutura voltada para o ensino e os laboratórios de informática, contemplando OUs para gestão de usuários, computadores (com subpastas para laboratórios, LAB-XX), bem como OUs específicas para o corpo discente (OU_Alunos) e docente (OU_Professores).

5.2. RAMO ADMINISTRATIVO (AD-ADM)

Agrupa os recursos do setor corporativo e de gestão. Subdivide-se em OUs para usuários, computadores, diretoria, coordenação, secretaria, administrativo e a equipe de TI.

5.3. REPRESENTAÇÃO DA ÁRVORE DE DIRETÓRIOS

Abaixo, a representação da arquitetura lógica adotada no domínio:

```
adm.fatecbarueri.local
├── AD-ACAD
│   ├── OU_Usuarios
│   ├── OU_Computadores
│   │   └── OU_Laboratorios
│   │       └── LAB-XX
│   ├── OU_Alunos
│   └── OU_Professores
└── AD-ADM
    ├── OU_Usuarios
    ├── OU_Computadores
    ├── OU_Diretoria
    ├── OU_Coordenacao
    ├── OU_Secretaria
    ├── OU_Administrativo
    └── OU_TI
```

6. FLUXOS DE PROVISIONAMENTO E CICLO DE VIDA DE IDENTIDADES

A implementação estruturada dos fluxos de provisionamento e ciclo de vida de identidades demonstra elevada eficácia operacional e mitigação de riscos. Ao padronizar rigorosamente todas as etapas, desde a criação automatizada até o expurgo seguro de contas inativas, a instituição garante que os princípios de segurança da informação — como o Princípio do Menor Privilégio e a Segregação de Funções — sejam aplicados de forma sistemática. Essa abordagem promove uma rastreabilidade completa das ações (accountability), reduz falhas humanas, evita a sobreposição indevida de permissões e impede de forma definitiva o acúmulo de acessos residuais que poderiam comprometer o ambiente tecnológico.

6.1. PROVISIONAMENTO DE CONTAS

Contas Acadêmicas (Alunos)

Etapa	Ação Técnica	Justificação / Regra Aplicada
1. Validação (SIGA)	Cruzamento dos dados do requerente com o SIGA.	Impedir credenciais não matriculadas.
2. Criação da Conta	Geração do objeto (nome.sobrenome) e senha	Obrigatoriedade de alteração no primeiro

	temporária.	logon.
3. Alocação (OU)	Movimentação para OU_Alunos (AD-ACAD).	Garantir herança de GPOs acadêmicas.
4. Permissões	Associação aos grupos de segurança do curso.	Aplicação do Princípio do Menor Privilégio.
5. Exceções	Desempate nominal e quarentena de contas trancadas.	Prevenir conflitos de identidade.

Contas Docentes (Professores)

Etapa	Ação Técnica	Justificação / Regra Aplicada
1. Validação	Recebimento de solicitação formal da Coordenação/RH.	Assegurar professores com contrato ativo.
2. Criação da Conta	Geração (nome.sobrenome) e senha temporária complexa.	Custódia da senha para o docente.
3. Alocação	Movimentação para OU_Professores.	Herança de GPOs ampliadas para ensino.
4. Permissões	Concessão de acesso às disciplinas.	Acesso focado nas necessidades de aula.
5. Ciclo de Vida	Em fim de contrato, bloqueio e quarentena.	Segurança após desligamento.

Contas Administrativas e Equipe TI

O fluxo para a equipe administrativa e técnica segue validações estritas da diretoria e gestão, aplicando movimentação para as OUs corporativas (OU_Administrativo, OU_TI) e atribuindo GPOs de segurança restritivas e auditorias avançadas.

6.2. MANUTENÇÃO E ALTERAÇÕES CADASTRAIS

Alteração Cadastral e Inclusão de Membros

Processo	Ação	Justificativa
Alteração	Atualização de atributos, movimentação de OU e revisão de grupos.	Prevenir acúmulo de privilégios e alinhar GPOs ao novo setor.
Inclusão	Análise de requisito, execução via ticket e teste de acesso.	Garantir o Princípio do Privilégio Mínimo.

Procedimento de Revogação de Acessos (Remoção de Grupos)

Etapa do Processo	Ação Técnica da Equipe	Justificação / Regra Aplicada
1. Autorização	Confirmação do término da necessidade via ITSM.	Impedir revogações indevidas.
2. Análise	Verificação de filiações sobrepostas (grupos aninhados).	Garantir eficácia técnica da restrição.
3. Execução	Remoção da conta do contentor de membros.	Aplicação prática no diretório.
4. Validação	Teste prático de Negação de Acesso.	Comprovar tecnicamente a supressão.
5. Auditoria	Registro da ação e evidência no ticket.	Assegurar rastreabilidade.

6.3. GESTÃO E RECUPERAÇÃO DE CREDENCIAIS

Reset de Senhas

Etapa	Ação Técnica	Justificação / Regra Aplicada

1. Validação	Confirmação de identidade via e-mail alternativo.	Prevenir ataques de personificação.
2. Redefinição	Desbloqueio (se aplicável) e nova senha provisória.	Restaurar acesso e mitigar força bruta.
3. Custódia	Alteração obrigatória no próximo login.	Transferir responsabilidade ao usuário.
4. Auditoria	Registro do processo em sistema de chamados.	Garantir rastreabilidade integral.
5. Exceções	Múltiplas solicitações geram bloqueio preventivo.	Detectar possíveis ataques direcionados.

Troca de Senhas Institucionais

Etapa	Atividade / Ação Técnica	Controle de Segurança
1. Orientação	Informar requisitos (mínimo de 14 caracteres).	Não registrar a senha em chamados.
2. Primeiro Acesso	Orientar a definir nova senha no primeiro login.	Troca obrigatória respeitada rigorosamente.
3. Redefinição	Redefinir anterior e permitir inserção de nova.	Nova senha não pode ser igual à anterior.
4. Validação	Testar autenticação de forma prática.	Validar o acesso ao perfil do usuário.
5. Tratamento de Exceções	Registrar falhas ou comprometimento suspeito.	Logs de autenticação sem expor credenciais.

6.4. DESLIGAMENTO, RETENÇÃO E EXPURGO

A exclusão definitiva elimina contas obsoletas, reduzindo drasticamente a superfície de ataque associada a credenciais inativas e vulneráveis.

Processo	Ação Técnica	Justificativa Aplicada

Desativação	Bloqueio instantâneo e isolamento de OU após notificação do SIGA/RH.	Privilégio zero inegociável para ex-colaboradores.
Reativação	Validação por ticket, habilitação e reset temporário.	Evitar reativação não autorizada.
Expurgo	Após 90 dias de retenção, deleção irreversível do objeto.	Conformidade com políticas de retenção institucionais.

7. POLÍTICAS DE SEGURANÇA E GOVERNANÇA

7.1. POLÍTICA DE CREDENCIAIS

Requisito	Diretriz Institucional	Justificativa Técnica
Mínimo de caracteres	A senha deverá possuir no mínimo 14 caracteres.	Dificulta tentativas de acesso indevido e amplia proteção.
Complexidade	Obrigatoriedade de maiúscula, minúscula, número e símbolo.	Aumenta rigidez contra invasões sistêmicas.
Troca no 1º Acesso	Alteração obrigatória no primeiro logon.	Impede uso contínuo da senha temporária de provisionamento.
Expiração	Ciclo de expiração obrigatório a cada 90 dias.	Estabelece renovação contra credenciais comprometidas.
Proteção de Credenciais	Senha inicial enviada via e-mail separado, nunca em chamados.	Evita exposição de informações de autenticação.
Separação de Contas	Proibição do uso de contas	Aplica rigorosamente a

	administrativas para o dia a dia.	Segregação de Funções (SoD).

7.2. REGRAS DE BLOQUEIO DE CONTAS

Parâmetro	Regra Estabelecida	Justificativa / Observação
Tentativas Inválidas	Bloqueio automático após 5 tentativas falhas.	Reduz ataques de força bruta à conta.
Bloqueio Automático	O bloqueio deverá impedir novas autenticações.	Suspender o acesso diante de ataques ativos.
Contas Inativas	Desativadas após 3 meses (90 dias) sem uso.	Reduz a permanência de identidades desnecessárias.
Expurgo	Deleção automatizada 90 dias após desativação.	Higiene do diretório e redução da superfície de ataque.
Registro de Eventos	Eventos de bloqueio/desbloqueio devem gerar logs.	Garantir rastreabilidade de operações para auditoria.

8. CONCLUSÃO

O desenvolvimento deste projeto consolidou as melhores práticas para a administração da infraestrutura de redes da Fatec Barueri. Através da implementação de políticas rigorosas de segregação de contas, padronização de nomenclatura, controle estruturado por OUs, gestão estrita de senhas e automação de rotinas, foi possível mitigar riscos de segurança, simplificar a auditoria de acessos e garantir um ambiente tecnológico resiliente e altamente disponível.

A documentação das políticas de governança no domínio adm.fatecbarueri.local constitui um marco para o padrão de qualidade do centro universitário, atestando o compromisso com a integridade e disponibilidade das informações institucionais.